
Segurança da Informação e Administração Segura de Bancos de Dados

Protegendo o ativo mais valioso das organizações — dos pilares da segurança à prática do DBA seguro

O que vamos aprender?

01

Dados como Ativo Corporativo

Por que proteger dados é prioridade estratégica — riscos, LGPD e Security by Design.

02

Segurança da Informação

A Triade CIA: Confidencialidade, Integridade e Disponibilidade.

03

Ataques Cibernéticos

Ransomware, SQL Injection, DDoS e credenciais comprometidas.

04

Administração Segura de BD

Menor privilégio, auditoria, backups e mascaramento de dados.

 Ao final desta aula, você saberá mapear ameaças e administrar bancos de dados com práticas defensivas consolidadas.

Dados: o ativo mais valioso das organizações

POR QUE PROTEGER DADOS?

Os dados sustentam decisões, **modelos de IA**, automação e a vantagem competitiva de qualquer empresa.

- ⚠ Vazamento ou perda geram prejuízos financeiros severos e danos irreparáveis à reputação.
- ⚖ Penalidades legais rigorosas previstas pela LGPD — Lei Geral de Proteção de Dados.

SEGURANÇA DA INFORMAÇÃO

Conceito fundamental

Conjunto de políticas, processos, controles e tecnologias que protegem a informação contra acessos não autorizados, modificações, interrupções ou destruição.

Não se limita à infraestrutura de TI: envolve pessoas, processos e conformidade regulatória.

Princípio: **Security by Design**

Triade CIA: a base da segurança da informação

Três pilares fundamentais sustentam toda política de proteção de dados

C

Confidencialidade

A informação é acessível apenas por pessoas, processos ou sistemas devidamente autorizados.

 **Exemplo: criptografia e controle de acesso estrito em tabelas com dados pessoais identificáveis.**

I

Integridade

Os dados mantêm exatidão, precisão e completude, protegidos contra alterações não autorizadas ou acidentais.

 **Exemplo: funções de hash para verificar se um arquivo de banco de dados foi modificado.**

A

Disponibilidade

Dados e sistemas estão acessíveis e operacionais sempre que os usuários autorizados precisarem.

 **Exemplo: planos de contingência, backups contínuos e alta disponibilidade com balanceamento de carga.**

Panorama de Ataques Cibernéticos

Ambientes orientados a dados são alvos constantes de ataques sofisticados. Conheça os 4 grandes vetores modernos.

01



Ransomware

Sequestro de dados por meio de **criptografia maliciosa**, exigindo resgate para a liberação das chaves de decodificação.

02



Injeção de SQL (SQL Injection)

Exploração de vulnerabilidades em aplicações web para executar **comandos arbitrários no banco de dados**, permitindo extrair ou destruir tabelas.

03



DDoS (Negação de Serviço)

Sobrecarga proposital dos servidores de banco de dados ou APIs para **derrubar a disponibilidade** dos sistemas.

04



Credenciais Comprometidas

Acesso indevido resultante do uso de **senhas fracas** ou do compartilhamento inadequado de chaves de acesso administrativas.

Administração Segura de Banco de Dados (DBA)

A DBA segura foca na implementação de **políticas e controles** que garantem a proteção, o desempenho e a conformidade das bases de dados.

O EQUILÍBRIO CENTRAL DA ADMINISTRAÇÃO SEGURA



Necessidade de acesso

Times de desenvolvimento e analytics precisam acessar os dados para criar soluções e gerar insights para o negócio.



Restrição da superfície de ataque

Cada acesso deve ser limitado ao estritamente necessário, reduzindo os pontos onde um atacante pode explorar vulnerabilidades.

ORGANIZAÇÃO E ESTRUTURA SEGURA

1

Segregação das bases

Segregação física ou lógica entre ambientes: dados de desenvolvimento **nunca** contêm dados reais de produção.

2

Schemas bem definidos

Estrutura organizada com esquemas claros e isolamento de instâncias do banco de dados.

3

Restrições de integridade

Aplicação correta de chaves, constraints e regras que impedem dados inconsistentes.

Ferramentas nativas de segurança dos SGBDs

Os Sistemas Gerenciadores de Banco de Dados (SGBDs) modernos fornecem ferramentas nativas para sustentar a segurança das bases de dados.

01



Auditoria (Audit Logs)

Registram **quem acessou, quando acessou** e **quais comandos SQL** foram executados — a base da rastreabilidade.

02



Gerenciamento de Acesso (IAM)

Identity and Access Management: **controle centralizado** de identidades e permissões de todos os usuários e serviços.

03



Módulos de Criptografia

Proteção do conteúdo dos dados tanto quando armazenados quanto quando trafegando pela rede.



Duas frentes de proteção: **dados em repouso** com TDE (Transparent Data Encryption) e **dados em trânsito** com TLS/SSL.

4 estratégias defensivas consolidadas

Para garantir a proteção contínua, a administração segura de bancos de dados adota um conjunto de práticas essenciais.

01 Princípio do Menor Privilegio

Cada usuário, serviço ou aplicação possui apenas os acessos **estritamente necessários** para realizar suas funções — nada além disso.

Least Privilege

02 Backup e Disaster Recovery

Backups **completos, diferenciais e de logs de transação**, com testes periódicos de restauração dos dados (Point-in-Time Recovery).

Pontos de Restauração

03 Mascaramento e Anonimização

Técnicas que **ocultam dados sensíveis** em ambientes de homologação e testes, evitando exposição de informações reais de clientes.

Data Masking

04 Hardening do SGBD

Desativação de recursos, portas e contas padrão não utilizadas, além da aplicação constante de patches de segurança.

Redução da Superfície de Ataque

Atividade 1: Mapeando a Triade CIA e as Ameaças

Analise os três cenários de incidentes abaixo e identifique: **qual pilar da Triade CIA foi violado**, o tipo de ataque ou falha e uma **medida corretiva**.

CENÁRIO A

Um desenvolvedor executou um **UPDATE sem a cláusula WHERE** em produção, alterando o status de **todos os clientes** para "Inativo".

I Integridade

FALHA Erro humano por falta de restrição e permissões inadequadas.

SOLUÇÃO Transações controladas, restrição de escrita em produção e restauração de backup.

CENÁRIO B

Um atacante explorou um **formulário de login** no site da empresa e exportou a lista completa de **cartões de crédito** dos clientes.

C Confidencialidade

FALHA Vulnerabilidade de SQL Injection no formulário.

SOLUÇÃO Sanitização de inputs, Prepared Statements e criptografia de dados sensíveis.

CENÁRIO C

O servidor de banco de dados sofreu um **ataque de DDoS** e a equipe de vendas **não emitiu notas fiscais** durante toda a tarde.

A Disponibilidade

FALHA Ataque de Negação de Serviço (DDoS).

SOLUÇÃO Firewall de aplicação (WAF), balanceamento de carga e proteção anti-DDoS.

Atividade 2: Roteiro SQL — Passo a Passo

> PRÁTICA · PARTE 1

Utilizando um SGBD (MySQL ou PostgreSQL), crie um script de administração que atenda aos requisitos de um ambiente corporativo.

1 Criar o banco de dados

```
CREATE DATABASE empresa_db;  
USE empresa_db;
```

2 Criar a tabela funcionários

```
CREATE TABLE funcionarios (  
  id          INT PRIMARY KEY AUTO_INCREMENT,  
  nome        VARCHAR(100) NOT NULL,  
  cargo       VARCHAR(50),  
  salario     DECIMAL(10,2)  
);
```

3 Criar três perfis de acesso distintos

Perfil 1 · Analista_Leitura — apenas leitura

```
CREATE USER 'analista_leitura'@'%' IDENTIFIED BY 'senha123';  
GRANT SELECT ON empresa_db.funcionarios TO 'analista_leitura'@'%';
```

Perfil 2 · Sistemas_Aplicação — leitura e escrita, sem DELETE/DROP

```
CREATE USER 'sistemas_app'@'%' IDENTIFIED BY 'senha456';  
GRANT SELECT, INSERT, UPDATE ON empresa_db.funcionarios TO 'sistemas_app'@'%';
```

Perfil 3 · DBA_Admin — permissões totais

```
CREATE USER 'dba_admin'@'%' IDENTIFIED BY 'senha789';  
GRANT ALL PRIVILEGES ON empresa_db.* TO 'dba_admin'@'%';  
FLUSH PRIVILEGES;
```



Observe: cada perfil recebe **apenas os privilégios necessários** — é o **Princípio do Menor Privilégio** aplicado na prática. Na Parte 2, testaremos as restrições criadas.

Atividade 2 — Teste de Acesso e Auditoria

ATIVIDADE PRÁTICA · 2/2

4 Testar acesso indevido

Conecte-se com o usuário do Perfil 1 (Analista_Leitura) e tente apagar um registro da tabela funcionarios:

```
-- Conectado como 'analista_leitura'  
DELETE FROM funcionarios  
WHERE id = 1;
```

- 🚫 **Resultado esperado: erro de permissão negada** (Access denied).
O sistema bloqueia a ação não autorizada automaticamente.

5 Consultar os logs de auditoria

Consulte o histórico de eventos para registrar e identificar quem tentou executar a ação não autorizada:

```
-- Consultando o histórico de eventos/auditoria  
SELECT event_time, user_host, sql_text  
FROM mysql.general_log  
WHERE command_type = 'Query';
```

- 🔍 **Objetivo:** identificar QUEM tentou executar a ação não autorizada e QUANDO ela ocorreu.



Mesmo quando o acesso é bloqueado, a auditoria garante **rastreabilidade** — essencial para conformidade com a LGPD e para a apuração de incidentes.

Perguntas de Fixação: o que você precisa dominar

- 1 A criptografia sozinha garante a integridade dos dados?**
Não. Ela garante a **confidencialidade**; a integridade exige funções de **hash**, **checksums** e controles de acesso estritos.
- 2 Qual a diferença entre autenticação e autorização?**
Autenticação = "**quem você é**" (verificar identidade, ex.: login). Autorização = "**o que você pode fazer**" (permissões dentro do banco).
- 3 Como o menor privilégio previne o impacto de um SQL Injection?**
Com a conexão da aplicação usando **permissões limitadas**, o atacante não consegue deletar tabelas, criar usuários ou acessar dados fora do escopo.
- 4 O que é o mascaramento de dados (Data Masking) e onde é indispensável?**
Cria uma versão **funcionalmente falsa** dos dados (ex.: ocultar dígitos de CPF). Indispensável em ambientes de **desenvolvimento**, **testes** e **homologação**.
- 5 Por que testar a restauração do backup é tão importante quanto executá-lo?**
Um backup só tem valor se for **restaurável**; sem testes periódicos, a empresa arrisca **perda definitiva de dados** no momento da crise.

*Segurança não é um obstáculo, é o **alicerce de uma infraestrutura de dados confiável**.*